ZecurX Cybersecurity Internship Program

Penetration Testing Internship Project-1

Full Web Application Penetration Testing

Submitted By

Name: Farzan AA
Domain: Penetration Testing

Submitted To

Organization: ZecurX Cybersecurity Internship Program

Project Duration

Submission Date: 24 March 2026

---

1. Objective

The objective of this project is to perform a complete web application security assessment following the OWASP Top 10 methodology and to develop a Python-based automated vulnerability scanner.

---

2. Methodology

- Reconnaissance
- Scanning & Enumeration
- Vulnerability Assessment
- Exploitation
- Automation
- Reporting

---

3. Tools Used

- Nmap
- Dirsearch
- Damn Vulnerable Web Application
- OWASP Juice Shop
- Python (Custom Vulnerability Scanner)

---

4. Target Application

- **Damn Vulnerable Web Application(DVWA)**

What is DVWA?

Damn Vulnerable Web Application

DVWA is an intentionally vulnerable web application used for learning and testing web security vulnerabilities.

Why DVWA was chosen

DVWA was chosen because it provides a safe environment to demonstrate vulnerabilities such as SQL Injection, XSS, CSRF, Broken Authentication, and Security Misconfiguration.

---

5. DVWA Setup and Configuration

5.1 Starting Services

The required services were started using the following commands:

- **sudo service apache2 start**
- **sudo service mysql start**

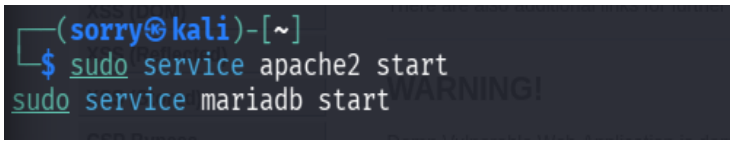


Figure 1: Starting Apache and MariaDB Services

5.2 Accessing DVWA

After starting the services, the DVWA application was accessed through the browser using:

- **http://localhost/DVWA**

5.3 Login

The application login page was opened, and the following default credentials were entered:

- **Username: admin**
- **Password: password**

After entering the credentials, successful login was achieved.

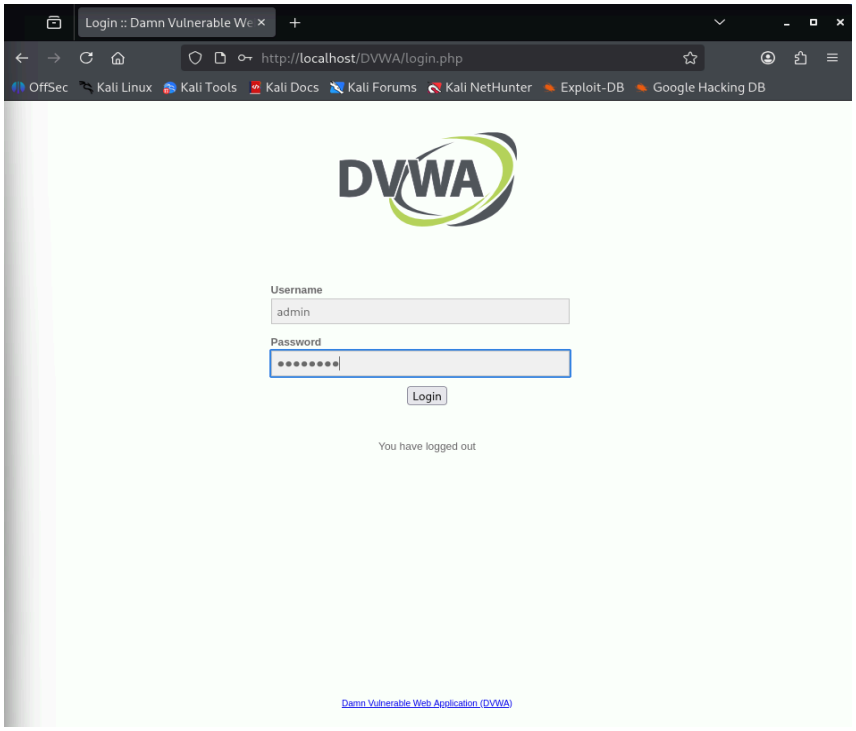


Figure 2: DVWA Login Page

5.4 Security Level Configuration

After logging in, the security level was configured:

- Navigated to **DVWA Security settings**
- Set the security level to **Low**

This allows vulnerabilities to be tested easily.

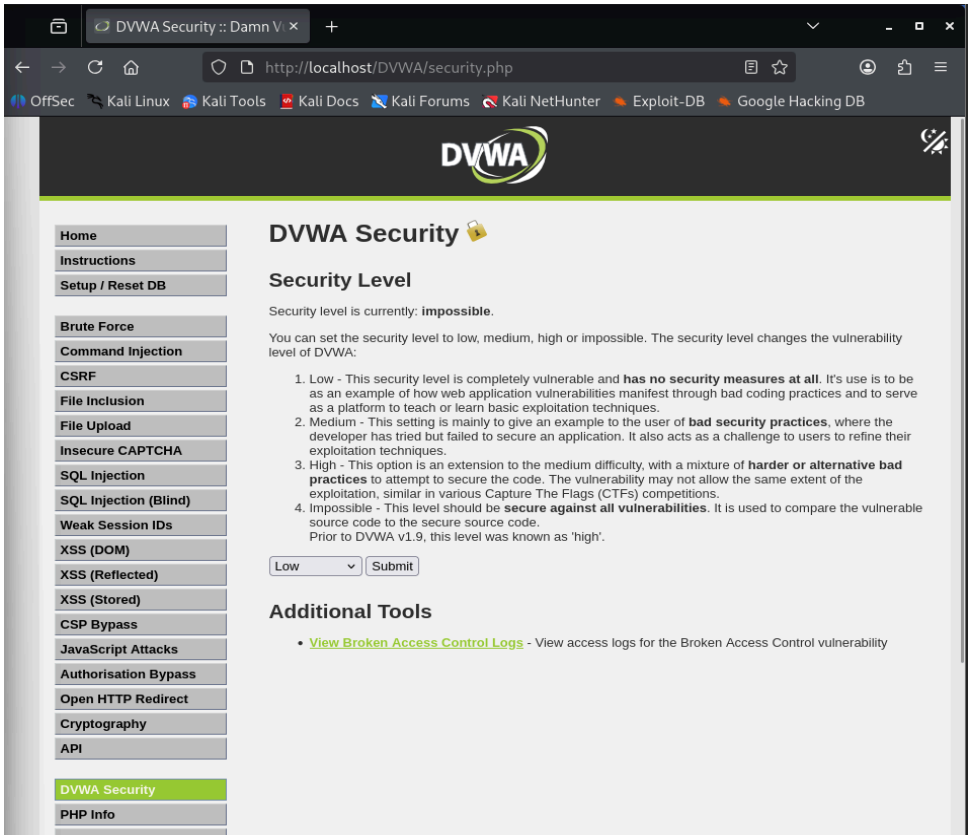


Figure 3: DVWA Security Level Set to Low

6. Reconnaissance and Scanning

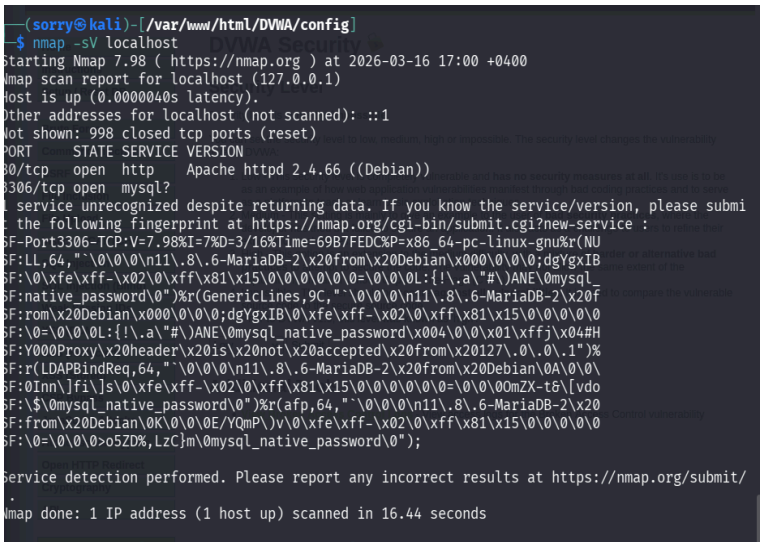
6.1 Network Scanning using Nmap

Used Nmap

- **nmap -sV localhost**

Result:

- **Port 80 → Apache HTTP**
- **Port 3306 → MySQL**



```
┌──(sorry㉿kali)-[/var/www/html/DVWA/config]
└─$ nmap -sV localhost
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-16 17:00 +0400
Nmap scan report for localhost (127.0.0.1)
Host is up (0.0000040s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 998 closed tcp ports (reset)
PORT     STATE SERVICE VERSION
80/tcp   open  http    Apache httpd 2.4.66 ((Debian))
3306/tcp open  mysql?
1 service unrecognized despite returning data. If you know the service/version, please submi
t the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port3306-TCP:V=7.98%I=7%D=3/16%Time=69B7FEDC%P=x86_64-pc-linux-gnu%r(NU
SF:LL,64,"`\0\0\0\n11\.8\.6-MariaDB-2\x20from\x20Debian\x000\0\0\0;dgYgxIB
SF:\0\xfe\xff-\x02\0\xff\x81\x15\0\0\0\0\0=\0\0\0L:{!\.a\"#\)ANE\0mysql_
SF:native_password\0")%r(GenericLines,9C,"`\0\0\0\n11\.8\.6-MariaDB-2\x20f
SF:rom\x20Debian\x000\0\0\0;dgYgxIB\0\xfe\xff-\x02\0\xff\x81\x15\0\0\0\0\0
SF:\0=\0\0\0L:{!\.a\"#\)ANE\0mysql_native_password\x004\0\0\x01\xffj\x04#H
SF:Y000Proxy\x20header\x20is\x20not\x20accepted\x20from\x20127\.0\.0\.1")%
SF:r(LDAPBindReq,64,"`\0\0\0\n11\.8\.6-MariaDB-2\x20from\x20Debian\0A\0\0\
SF:0Inn\]fi\]s\0\xfe\xff-\x02\0\xff\x81\x15\0\0\0\0\0=\0\0\0OmZX-t&\[vdo
SF:\$\0mysql_native_password\0")%r(afp,64,"`\0\0\0\n11\.8\.6-MariaDB-2\x20
SF:from\x20Debian\0K\0\0\0E/YQmP\)v\0\xfe\xff-\x02\0\xff\x81\x15\0\0\0\0\0
SF:\0=\0\0\0>o5ZD%,LzC}m\0mysql_native_password\0");

Service detection performed. Please report any incorrect results at https://nmap.org/submit/
.
Nmap done: 1 IP address (1 host up) scanned in 16.44 seconds
```

Figure 4: Nmap Scan Results

Analysis:

- Web server and database exposed
- Increased attack surface

6.2 Directory Enumeration using Dirsearch

Used Dirsearch

- **dirsearch -u http://localhost/DVWA**

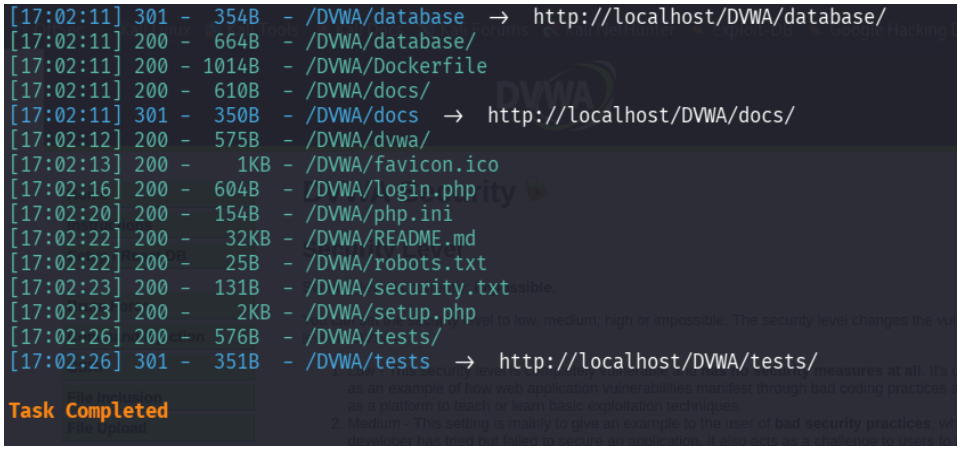
Result:

- Discovered directories: `/config`, `/database`, `.git`

```
┌──(sorry㉿kali)-[/var/www/html/DVWA/config]
└─$ dirsearch -u http://localhost/DVWA
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources
is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

  _|. _ _  _  _  _ _|_    v0.4.3
 (_||| _) (/_(_|| (_| )

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25
Wordlist size: 11460

Output File: /var/www/html/DVWA/config/reports/http_localhost/_DVWA_26-03-16_17-01-58.txt

Target: http://localhost/

[17:01:58] Starting: DVWA/
[17:01:59] 200 -   80B  - /DVWA/.dockerignore
[17:01:59] 301 -  350B  - /DVWA/.git  →  http://localhost/DVWA/.git/
[17:01:59] 200 -  687B  - /DVWA/.git/
[17:01:59] 200 -   73B  - /DVWA/.git/description
[17:01:59] 200 -  262B  - /DVWA/.git/config
[17:01:59] 200 -   23B  - /DVWA/.git/HEAD
[17:01:59] 200 -  794B  - /DVWA/.git/hooks/
[17:01:59] 200 -   27KB - /DVWA/.git/index
[17:01:59] 200 -  556B  - /DVWA/.git/info/
[17:01:59] 200 -  580B  - /DVWA/.git/logs/
[17:01:59] 200 -  240B  - /DVWA/.git/info/exclude
[17:01:59] 200 -  172B  - /DVWA/.git/logs/HEAD
[17:01:59] 301 -  366B  - /DVWA/.git/logs/refs/heads  →  http://localhost/DVWA/.git/logs/re
fs/heads/
[17:01:59] 301 -  368B  - /DVWA/.git/logs/refs/remotes  →  http://localhost/DVWA/.git/logs/
refs/remotes/
[17:01:59] 301 -  360B  - /DVWA/.git/logs/refs  →  http://localhost/DVWA/.git/logs/refs/
[17:01:59] 200 -  172B  - /DVWA/.git/logs/refs/heads/master
[17:01:59] 301 -  375B  - /DVWA/.git/logs/refs/remotes/origin  →  http://localhost/DVWA/.gi
t/logs/refs/remotes/origin/
[17:01:59] 200 -  172B  - /DVWA/.git/logs/refs/remotes/origin/HEAD
```

Figure 5: Directory Enumeration Results

```
t/logs/refs/remotes/origin/
[17:01:59] 200 -  172B  - /DVWA/.git/logs/refs/remotes/origin/HEAD
[17:01:59] 200 -  570B  - /DVWA/.git/refs/
[17:01:59] 200 -  562B  - /DVWA/.git/objects/
[17:01:59] 200 -  837B  - /DVWA/.git/packed-refs
[17:01:59] 200 -   41B  - /DVWA/.git/refs/heads/master
[17:01:59] 301 -  361B  - /DVWA/.git/refs/heads  →  http://localhost/DVWA/.git/refs/heads/
[17:01:59] 301 -  363B  - /DVWA/.git/refs/remotes  →  http://localhost/DVWA/.git/refs/remot
es/
[17:01:59] 301 -  370B  - /DVWA/.git/refs/remotes/origin  →  http://localhost/DVWA/.git/ref
s/remotes/origin/
[17:01:59] 301 -  360B  - /DVWA/.git/refs/tags  →  http://localhost/DVWA/.git/refs/tags/
[17:01:59] 200 -   32B  - /DVWA/.git/refs/remotes/origin/HEAD
[17:01:59] 200 -  474B  - /DVWA/.gitattributes
[17:01:59] 200 -  610B  - /DVWA/.github/
[17:01:59] 200 -  293B  - /DVWA/.gitignore
[17:01:59] 403 -  314B  - /DVWA/.ht_wsr.txt
[17:01:59] 403 -  314B  - /DVWA/.htaccess.orig
[17:01:59] 403 -  314B  - /DVWA/.htaccess.save
[17:01:59] 403 -  314B  - /DVWA/.htaccess.sample
[17:01:59] 403 -  314B  - /DVWA/.htaccess.bak1
[17:01:59] 403 -  314B  - /DVWA/.htaccess_extra
[17:01:59] 403 -  314B  - /DVWA/.htaccess_orig
[17:01:59] 403 -  314B  - /DVWA/.htaccess_sc
[17:01:59] 403 -  314B  - /DVWA/.htaccessBAK
[17:01:59] 403 -  314B  - /DVWA/.htaccessOLD
[17:01:59] 403 -  314B  - /DVWA/.htm
[17:01:59] 403 -  314B  - /DVWA/.htaccessOLD2
[17:01:59] 403 -  314B  - /DVWA/.html
[17:01:59] 403 -  314B  - /DVWA/.htpasswd_test
[17:01:59] 403 -  314B  - /DVWA/.htpasswds
[17:01:59] 403 -  314B  - /DVWA/.httr-oauth
[17:02:00] 403 -  314B  - /DVWA/.php
[17:02:02] 200 -    2KB - /DVWA/about.php
[17:02:09] 200 -    7KB - /DVWA/CHANGELOG.md
[17:02:10] 301 -  352B  - /DVWA/config  →  http://localhost/DVWA/config/
[17:02:10] 200 -  618B  - /DVWA/config/
[17:02:11] 301 -  354B  - /DVWA/database  →  http://localhost/DVWA/database/
```



```
[17:02:11] 301 -  354B  - /DVWA/database  →  http://localhost/DVWA/database/
[17:02:11] 200 -  664B  - /DVWA/database/
[17:02:11] 200 - 1014B  - /DVWA/Dockerfile
[17:02:11] 200 -  610B  - /DVWA/docs/
[17:02:11] 301 -  350B  - /DVWA/docs  →  http://localhost/DVWA/docs/
[17:02:12] 200 -  575B  - /DVWA/dvwa/
[17:02:13] 200 -    1KB - /DVWA/favicon.ico
[17:02:16] 200 -  604B  - /DVWA/login.php
[17:02:20] 200 -  154B  - /DVWA/php.ini
[17:02:22] 200 -   32KB - /DVWA/README.md
[17:02:22] 200 -   25B  - /DVWA/robots.txt
[17:02:23] 200 -  131B  - /DVWA/security.txt
[17:02:23] 200 -    2KB - /DVWA/setup.php
[17:02:26] 200 - 576B   - /DVWA/tests/
[17:02:26] 301 -  351B  - /DVWA/tests  →  http://localhost/DVWA/tests/

Task Completed
```

Figure 6: Additional Findings

Analysis:

- Sensitive files exposed
- Indicates poor configuration

---

7. Manual Vulnerability Testing (DVWA)

7.1 SQL Injection

Payload:

- **' OR 1=1--**

Steps:

1. Open SQL Injection module
2. Enter payload

Result:

- Multiple user records displayed

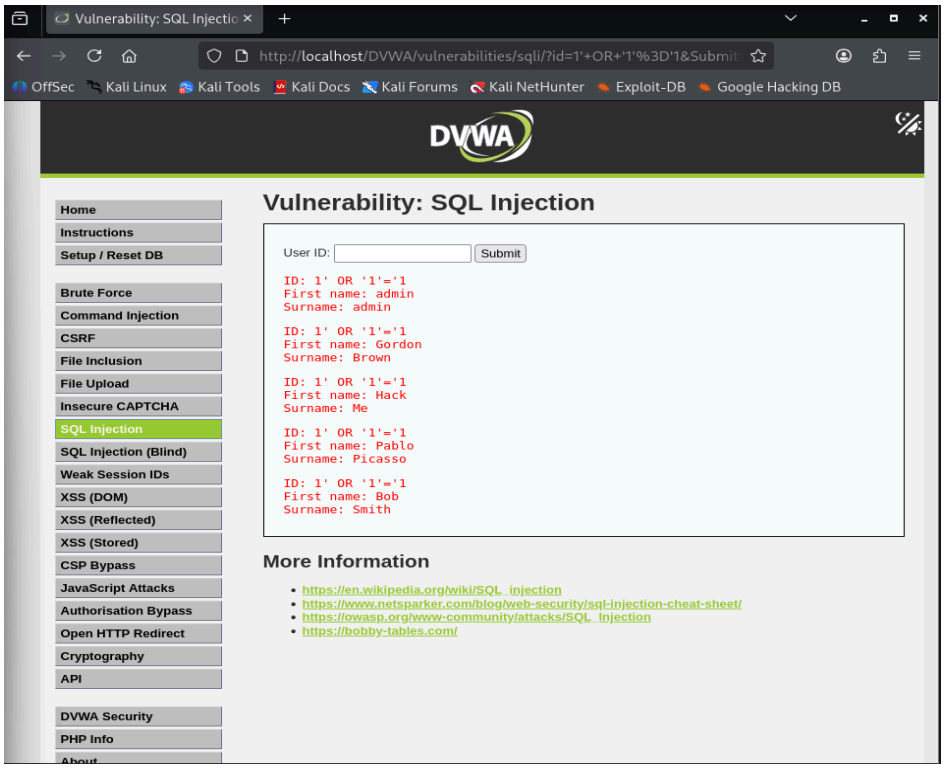


Figure 7: SQL Injection Result

Impact:

- Unauthorized database access

Conclusion:

SQL Injection vulnerability exists.

7.2 Cross-Site Scripting (XSS)

Payload:

- **<script>alert(1)</script>**

Steps:

1. Open XSS module
2. Submit payload

Result:

- Alert popup executed

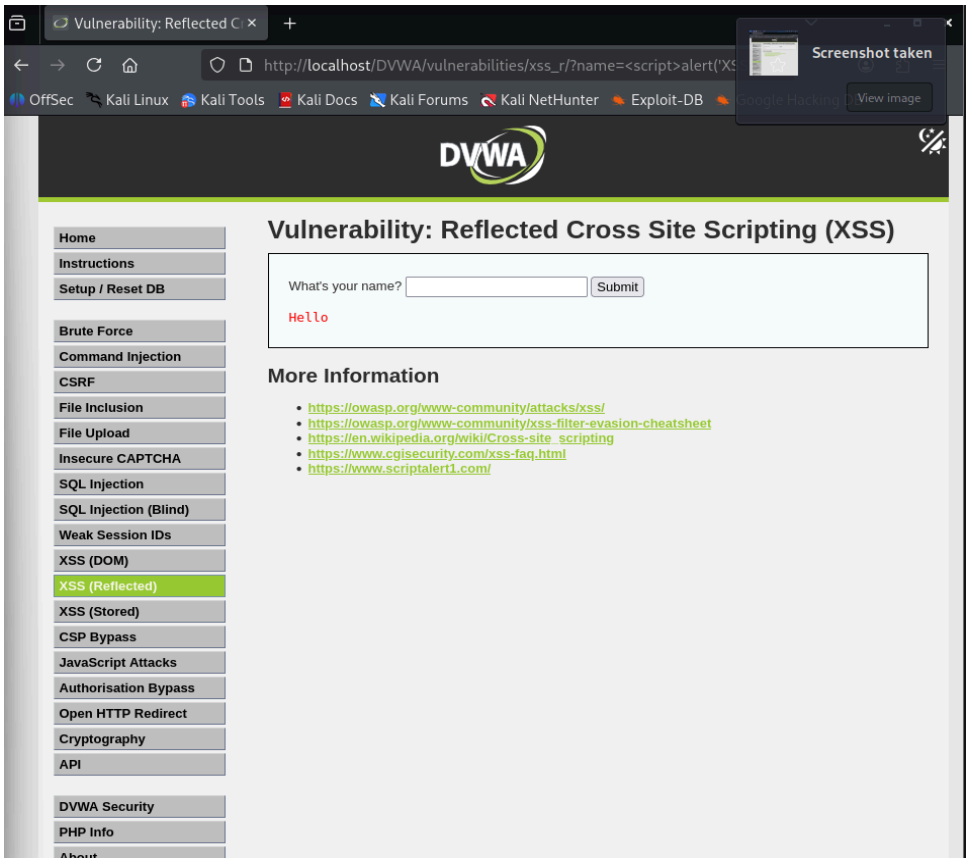


Figure 8: XSS Payload Input

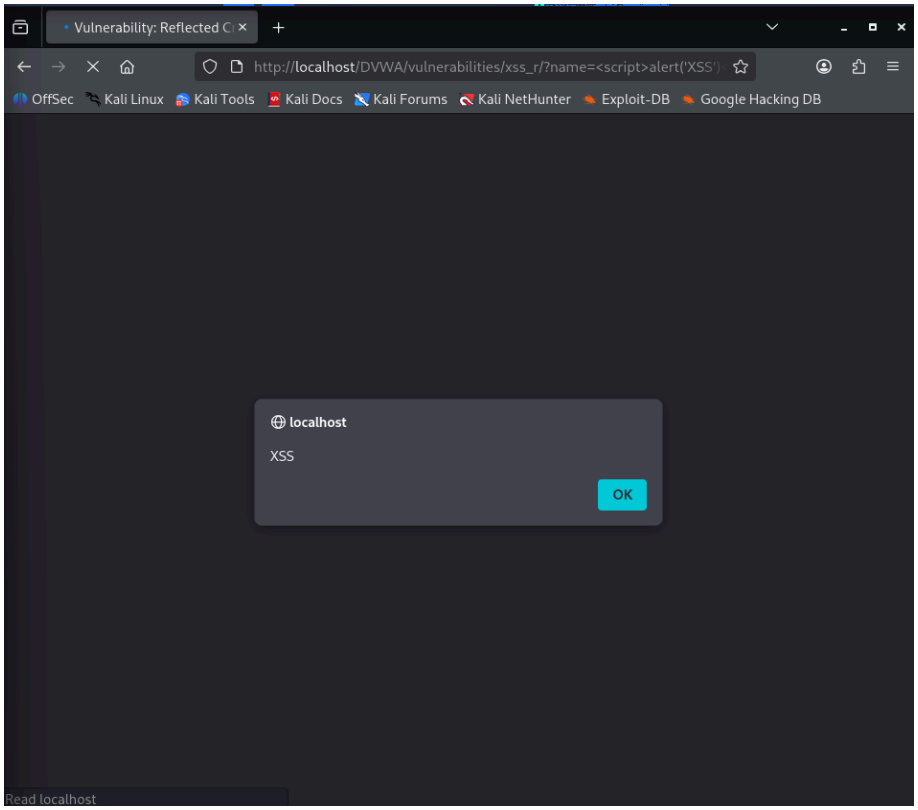


Figure 9: XSS Alert Execution

Impact:

- Malicious script execution

Conclusion:

XSS vulnerability exists.

7.3 Cross-Site Request Forgery (CSRF)

Steps:

1. Open CSRF module
2. Change password

Result:

- Password changed

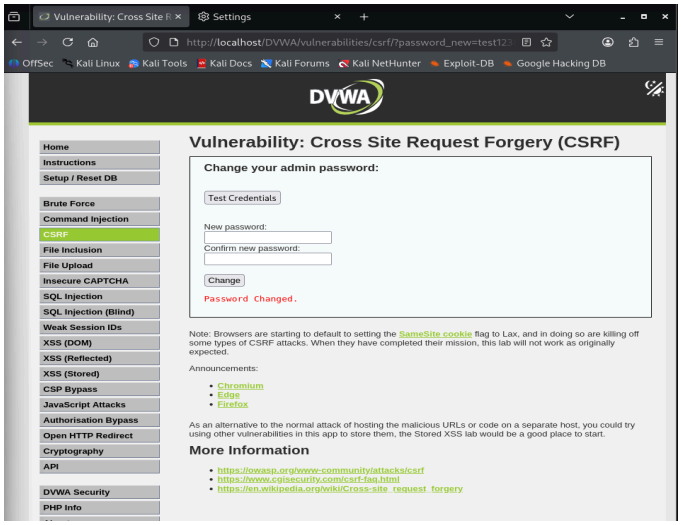


Figure 10: CSRF Exploitation

Impact:

- Unauthorized actions

Conclusion:

CSRF vulnerability exists.

7.4 Broken Authentication

Steps:

1. Login using default credentials

Result:

- Access granted

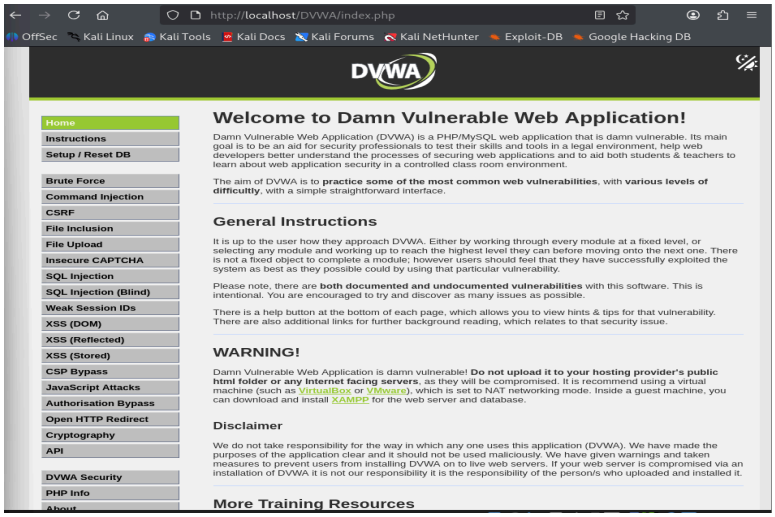


Figure 11: Login Success

Impact:

- Unauthorized access

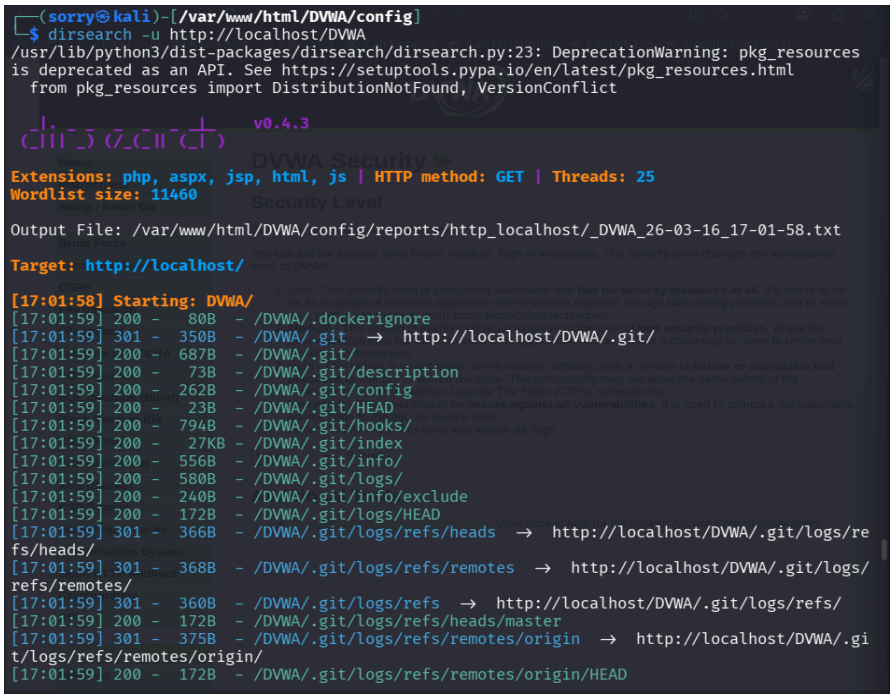
Conclusion:

Weak authentication exists.

7.5 Security Misconfiguration

Result:

- Sensitive directories exposed



```
┌──(sorry㉿kali)-[/var/www/html/DVWA/config]
└─$ dirsearch -u http://localhost/DVWA
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources
is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

  _|. _ _  _  _  _ _|_    v0.4.3
 (_||| _) (/_(_|| (_| )

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25
Wordlist size: 11460

Output File: /var/www/html/DVWA/config/reports/http_localhost/_DVWA_26-03-16_17-01-58.txt

Target: http://localhost/

[17:01:58] Starting: DVWA/
[17:01:59] 200 -   80B  - /DVWA/.dockerignore
[17:01:59] 301 -  350B  - /DVWA/.git  →  http://localhost/DVWA/.git/
[17:01:59] 200 - 687B  - /DVWA/.git/
[17:01:59] 200 -   73B  - /DVWA/.git/description
[17:01:59] 200 -  262B  - /DVWA/.git/config
[17:01:59] 200 -   23B  - /DVWA/.git/HEAD
[17:01:59] 200 -  794B  - /DVWA/.git/hooks/
[17:01:59] 200 -   27KB - /DVWA/.git/index
[17:01:59] 200 -  556B  - /DVWA/.git/info/
[17:01:59] 200 -  580B  - /DVWA/.git/logs/
[17:01:59] 200 -  240B  - /DVWA/.git/info/exclude
[17:01:59] 200 -  172B  - /DVWA/.git/logs/HEAD
[17:01:59] 301 -  366B  - /DVWA/.git/logs/refs/heads  →  http://localhost/DVWA/.git/logs/re
fs/heads/
[17:01:59] 301 -  368B  - /DVWA/.git/logs/refs/remotes  →  http://localhost/DVWA/.git/logs/
refs/remotes/
[17:01:59] 301 -  360B  - /DVWA/.git/logs/refs  →  http://localhost/DVWA/.git/logs/refs/
[17:01:59] 200 -  172B  - /DVWA/.git/logs/refs/heads/master
[17:01:59] 301 -  375B  - /DVWA/.git/logs/refs/remotes/origin  →  http://localhost/DVWA/.gi
t/logs/refs/remotes/origin/
[17:01:59] 200 -  172B  - /DVWA/.git/logs/refs/remotes/origin/HEAD
```

Figure 12: Directory Exposure

Impact:

- Information disclosure

Conclusion:

Misconfiguration vulnerability exists.

---

8. Part 2 — Automated Tool Testing

8.1 Tool Description

A Python-based web vulnerability scanner was developed to automate testing.

8.2 Features

- Directory scanning
- XSS testing
- SQL Injection testing
- Multiple payloads
- Automated reporting

8.3 Execution

- **python3 advanced_scanner.py**

8.4 Target

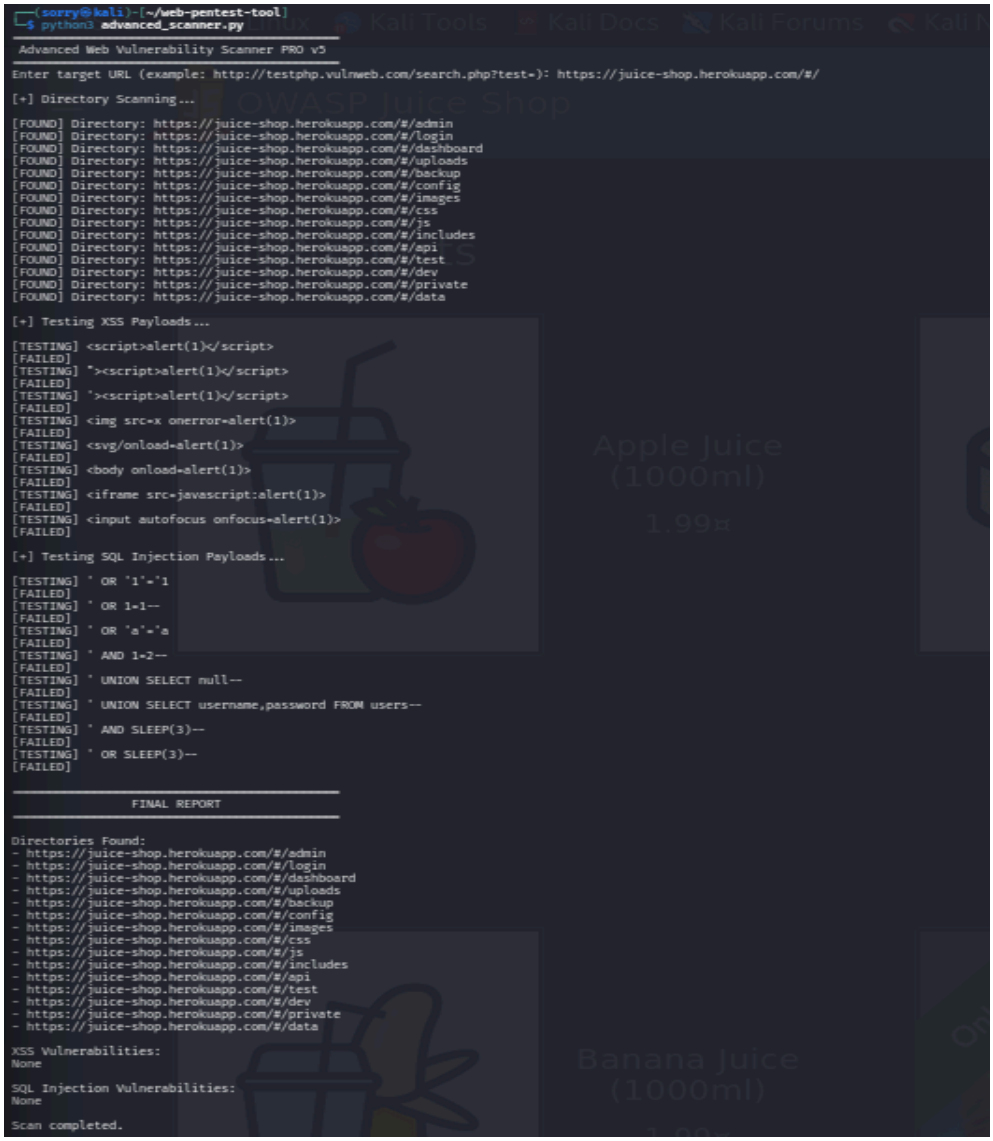
OWASP Juice Shop

- **https://juice-shop.herokuapp.com/#/**

8.5 Results

- Directories found
- No XSS detected
- No SQL Injection detected

Screenshots:



```
┌──(sorry㉿kali)-[~/web-pentest-tool]
└─$ python3 advanced_scanner.py
═══════════════════════════════════════
 Advanced Web Vulnerability Scanner PRO v5
═══════════════════════════════════════
Enter target URL (example: http://testphp.vulnweb.com/search.php?test=): https://juice-shop.herokuapp.com/#/

[+] Directory Scanning...

[FOUND] Directory: https://juice-shop.herokuapp.com/#/admin
[FOUND] Directory: https://juice-shop.herokuapp.com/#/login
[FOUND] Directory: https://juice-shop.herokuapp.com/#/dashboard
[FOUND] Directory: https://juice-shop.herokuapp.com/#/uploads
[FOUND] Directory: https://juice-shop.herokuapp.com/#/backup
[FOUND] Directory: https://juice-shop.herokuapp.com/#/config
[FOUND] Directory: https://juice-shop.herokuapp.com/#/images
[FOUND] Directory: https://juice-shop.herokuapp.com/#/css
[FOUND] Directory: https://juice-shop.herokuapp.com/#/js
[FOUND] Directory: https://juice-shop.herokuapp.com/#/includes
[FOUND] Directory: https://juice-shop.herokuapp.com/#/api
[FOUND] Directory: https://juice-shop.herokuapp.com/#/test
[FOUND] Directory: https://juice-shop.herokuapp.com/#/dev
[FOUND] Directory: https://juice-shop.herokuapp.com/#/private
[FOUND] Directory: https://juice-shop.herokuapp.com/#/data

[+] Testing XSS Payloads...

[TESTING] <script>alert(1)</script>
[FAILED]
[TESTING] "><script>alert(1)</script>
[FAILED]
[TESTING] '><script>alert(1)</script>
[FAILED]
[TESTING] <img src=x onerror=alert(1)>
[FAILED]
[TESTING] <svg/onload=alert(1)>
[FAILED]
[TESTING] <body onload=alert(1)>
[FAILED]
[TESTING] <iframe src=javascript:alert(1)>
[FAILED]
[TESTING] <input autofocus onfocus=alert(1)>
[FAILED]

[+] Testing SQL Injection Payloads...

[TESTING] ' OR '1'='1
[FAILED]
[TESTING] ' OR 1=1--
[FAILED]
[TESTING] ' OR 'a'='a
[FAILED]
[TESTING] ' AND 1=2--
[FAILED]
[TESTING] ' UNION SELECT null--
[FAILED]
[TESTING] ' UNION SELECT username,password FROM users--
[FAILED]
[TESTING] ' AND SLEEP(3)--
[FAILED]
[TESTING] ' OR SLEEP(3)--
[FAILED]

═══════════════════════════════════════
                FINAL REPORT
═══════════════════════════════════════

Directories Found:
- https://juice-shop.herokuapp.com/#/admin
- https://juice-shop.herokuapp.com/#/login
- https://juice-shop.herokuapp.com/#/dashboard
- https://juice-shop.herokuapp.com/#/uploads
- https://juice-shop.herokuapp.com/#/backup
- https://juice-shop.herokuapp.com/#/config
- https://juice-shop.herokuapp.com/#/images
- https://juice-shop.herokuapp.com/#/css
- https://juice-shop.herokuapp.com/#/js
- https://juice-shop.herokuapp.com/#/includes
- https://juice-shop.herokuapp.com/#/api
- https://juice-shop.herokuapp.com/#/test
- https://juice-shop.herokuapp.com/#/dev
- https://juice-shop.herokuapp.com/#/private
- https://juice-shop.herokuapp.com/#/data

XSS Vulnerabilities:
None

SQL Injection Vulnerabilities:
None

Scan completed.
```

- Tool_execution.png

```
┌──(sorry㉿kali)-[~/web-pentest-tool]
└─$ python3 advanced_scanner.py
═══════════════════════════════════
Advanced Web Vulnerability Scanner PRO v5
═══════════════════════════════════
Enter target URL (example: http://testphp.vulnweb.com/search.php?test=): https://juice-shop.herokuapp.com/#/admin

[+] Directory Scanning ...
[FOUND] Directory: https://juice-shop.herokuapp.com/#/admin/admin
[FOUND] Directory: https://juice-shop.herokuapp.com/#/admin/login
[FOUND] Directory: https://juice-shop.herokuapp.com/#/admin/dashboard
[FOUND] Directory: https://juice-shop.herokuapp.com/#/admin/uploads
[FOUND] Directory: https://juice-shop.herokuapp.com/#/admin/backup
[FOUND] Directory: https://juice-shop.herokuapp.com/#/admin/config
[FOUND] Directory: https://juice-shop.herokuapp.com/#/admin/images
[FOUND] Directory: https://juice-shop.herokuapp.com/#/admin/css
[FOUND] Directory: https://juice-shop.herokuapp.com/#/admin/js
[FOUND] Directory: https://juice-shop.herokuapp.com/#/admin/includes
[FOUND] Directory: https://juice-shop.herokuapp.com/#/admin/api
[FOUND] Directory: https://juice-shop.herokuapp.com/#/admin/test
[FOUND] Directory: https://juice-shop.herokuapp.com/#/admin/dev
[FOUND] Directory: https://juice-shop.herokuapp.com/#/admin/private
[FOUND] Directory: https://juice-shop.herokuapp.com/#/admin/data
```

- directory_scan.png

```
XSS Vulnerabilities:
None

SQL Injection Vulnerabilities:
None

Scan completed.
```

- no_vulnerabilities.png

Conclusion: **Application is secure.**

---

9. Risk Classification (CVSS)

Vulnerability	Score	Severity
SQL Injection	9.0	Critical
XSS	7.5	High
CSRF	8.0	High
Broken Authentication	8.5	High
Misconfiguration	6.5	Medium

---

10. Remediation Recommendations

- Input validation
- Parameterized queries
- CSRF protection
- Strong authentication
- Restrict directories
- Regular testing

---

11. Conclusion

The project demonstrated both manual and automated penetration testing.

DVWA confirmed real vulnerabilities, while the custom tool demonstrated automated scanning capabilities.

Signature: FARZAN AA
Date: 24/03/2026